
VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Target	http://testphp.vulnweb.com/
Scan ID	767e0843-eac6-47...
Date	2026-02-21 12:26:57
Classification	CONFIDENTIAL
Tool	Advanced VAPT Scanner v1.0
Methodology	OWASP Top 10 / PTES / NIST SP 800-115

1. Executive Summary

A comprehensive vulnerability assessment and penetration test was conducted against the target 'http://testphp.vulnweb.com/'. The assessment identified 9 security findings, comprising 0 Critical, 0 High, 3 Medium, and 6 Low severity issues. The overall risk rating for the target is assessed as **Medium**. Immediate remediation of Critical and High severity findings is strongly recommended.

Risk Level	Critical	High	Medium	Low
Count	0	0	3	6

Overall Risk Rating: Medium

2. Scope & Methodology

The assessment was conducted against the target: **http://testphp.vulnweb.com/**. The scope included all web-facing assets, open ports, subdomains, APIs, and the application layer. The methodology followed OWASP Testing Guide v4, PTES (Penetration Testing Execution Standard), and NIST SP 800-115.

Phase	Description	Tools/Techniques
Reconnaissance	Technology detection, crawling, subdomain discovery, dir fuzzing	Custom scanner, HTTP analysis
Enumeration	Port scanning, service enum, OS detection, banner grabbing	Socket scanning, banner analysis
Vulnerability Scanning	XSS, SQLi, IDOR, header analysis, SSL, API discovery, OWASP	Payload injection, header inspection
Analysis	CVSS scoring, severity classification, PoC simulation, remediation	CVSS v3.1 calculator, risk matrix

3. Reconnaissance Findings

3.1 Technology Detection

Component	Detected Value
Server	nginx/1.19.0
Powered By	PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1
CMS	
Frameworks	None detected
Languages	PHP

3.2 Web Crawl Results

Pages crawled: 3 | Links found: 13 | Forms discovered: 2

3.3 Directory Fuzzing

Total paths checked: 29 | Paths found: 1 | Interesting: 1

Path	URL	Status
admin	http://testphp.vulnweb.com/admin...	200

4. Enumeration Findings

4.1 Port Scan Results

Host: testphp.vulnweb.com | IP: 44.228.249.3 | Ports scanned: 26 | Open ports: 1

4.2 Service Enumeration

Port	Service	Risk	Banner
80	HTTP	Low	

5. Vulnerability Details

1. Missing Security Header [Medium] CVSS: 4.3

Description: Missing X-Frame-Options - Clickjacking vulnerability

Remediation: Add: X-Frame-Options: DENY or SAMEORIGIN

2. Missing Security Header [Medium] CVSS: 5.0

Description: Missing Content-Security-Policy header

Remediation: Implement a strict CSP policy

3. Missing Security Header [Medium] CVSS: 4.8

Description: Missing HSTS header - Downgrade attack possible

Remediation: Add: Strict-Transport-Security: max-age=31536000; includeSubDomains

4. Missing Security Header [Low] CVSS: 3.1

Description: Missing X-Content-Type-Options - MIME sniffing vulnerability

Remediation: Add: X-Content-Type-Options: nosniff

5. Missing Security Header [Low] CVSS: 3.1

Description: Missing X-XSS-Protection header

Remediation: Add: X-XSS-Protection: 1; mode=block

6. Missing Security Header [Low] CVSS: 2.6

Description: Missing Referrer-Policy header - Information leakage

Remediation: Add: Referrer-Policy: strict-origin-when-cross-origin

7. Missing Security Header [Low] CVSS: 2.0

Description: Missing Permissions-Policy header

Remediation: Add: Permissions-Policy: camera=(), microphone=(), geolocation=()

8. Information Disclosure [Low] CVSS: 2.0

Description: Server header reveals: nginx/1.19.0

Remediation: Remove or obfuscate the Server header

9. Information Disclosure [Low] CVSS: 2.0

Description: X-Powered-By reveals: PHP/5.6.40-38+ubuntu20.04.1+deb.sury.org+1

Remediation: Remove the X-Powered-By header

6. Risk Ratings

OWASP Category	Status	Severity	CVSS
A01 - Broken Access Control	Checked	High	7.5
A02 - Cryptographic Failures	HTTPS not enforced	High	7.5
A03 - Injection	Checked via payload testing	Critical	9.8
A05 - Security Misconfiguration	Checked	Medium	5.3
A06 - Vulnerable and Outdated Components	Component versions analyzed	Medium	5.5
A07 - Identification and Authentication Failures	No lockout mechanism detected	High	7.5
A08 - Software and Data Integrity Failures	SRI check performed	Medium	4.8
A09 - Security Logging and Monitoring Failures	Manual review recommended	Medium	4.3
A10 - Server-Side Request Forgery (SSRF)	Basic SSRF patterns checked	High	7.2

7. Remediation Recommendations

Missing Security Header

Priority: Medium | Add: X-Frame-Options: DENY or SAMEORIGIN

Missing Security Header

Priority: Medium | Implement a strict CSP policy

Missing Security Header

Priority: Medium | Add: Strict-Transport-Security: max-age=31536000; includeSubDomains

Missing Security Header

Priority: Low | Add: X-Content-Type-Options: nosniff

Missing Security Header

Priority: Low | Add: X-XSS-Protection: 1; mode=block

Missing Security Header

Priority: Low | Add: Referrer-Policy: strict-origin-when-cross-origin

Missing Security Header

Priority: Low | Add: Permissions-Policy: camera=(), microphone=(), geolocation=()

Information Disclosure

Priority: Low | Remove or obfuscate the Server header

Information Disclosure

Priority: Low | Remove the X-Powered-By header

8. Conclusion

The automated VAPT assessment of 'http://testphp.vulnweb.com/' has been completed. The target demonstrates a Medium overall security posture. Key areas requiring immediate attention include: 0 critical vulnerabilities and 0 high-severity issues. It is recommended that the development and security teams prioritize remediation of critical and high-severity findings before re-assessment. A follow-up pentest is advised after remediation to validate that all identified vulnerabilities have been resolved. All testing was performed in a controlled, authorized manner following ethical security research practices.

This report was generated automatically by Advanced VAPT Scanner v1.0 on 2026-02-21 12:26:57. For academic and authorized security testing use only.